

CSE 331: Computer Security Fundamentals

Spring 2026

Network Security:
SSL/TLS

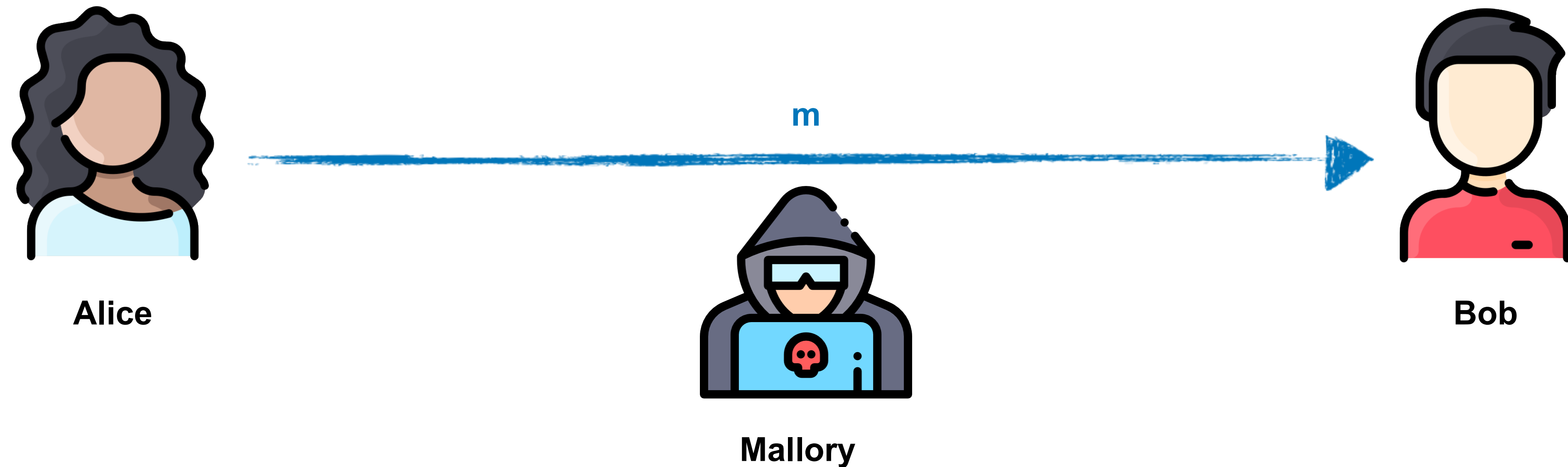
Amir Rahmati
Xinrui Yu



Stony Brook Institute
at Anhui University

安徽大学纽约石溪学院

The Problem



- **Defender Goal:** Should be able to “surf the Internet” no matter where you are
- **Threat model:** Attacker completely controls the network. They control Wi-Fi, DNS, routers, have their own websites, can listen to any packet, modify packets in transit, inject his own packets into the network.

Wait a second...
Didn't public key crypto solve it already?

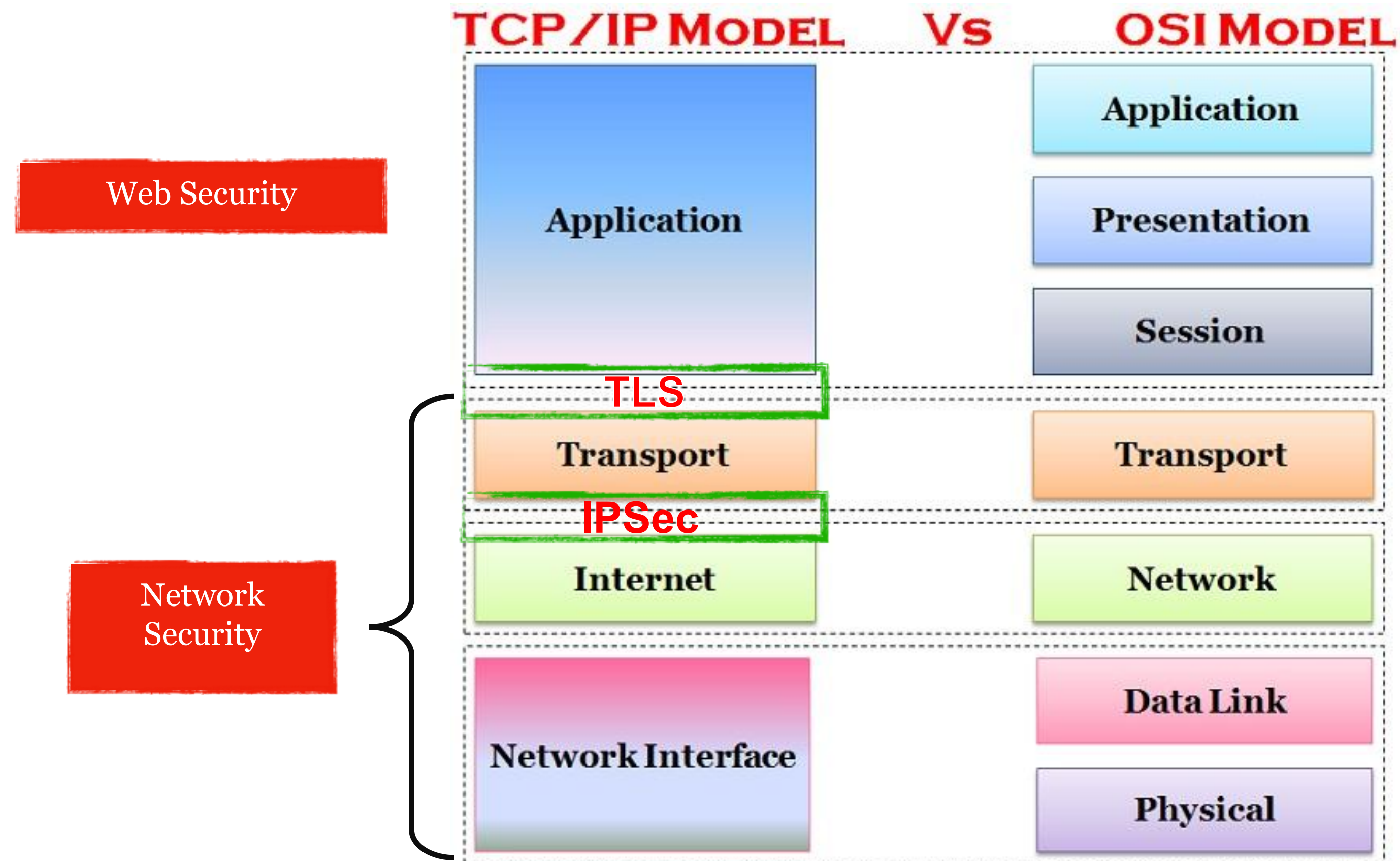
No!

- Crypto gives us the building blocks, but still lot to build:
 - How does Alice know the public key of Bob?
 - How to decide what to encrypt and what not?
 - How is the “secure” connection initiated? What is the protocol?

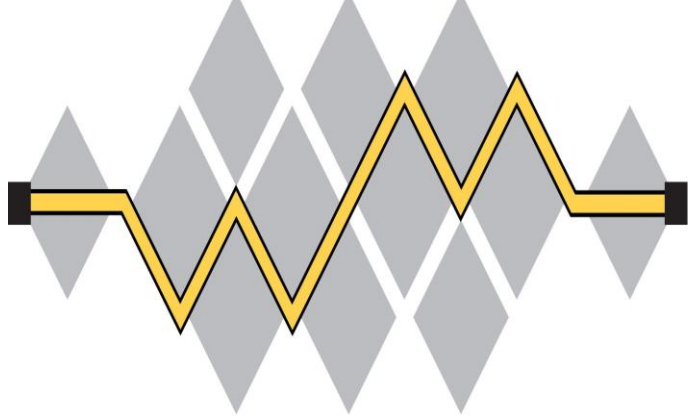


Network 101:

Open Systems Internet Model



Transport layer security (TLS)

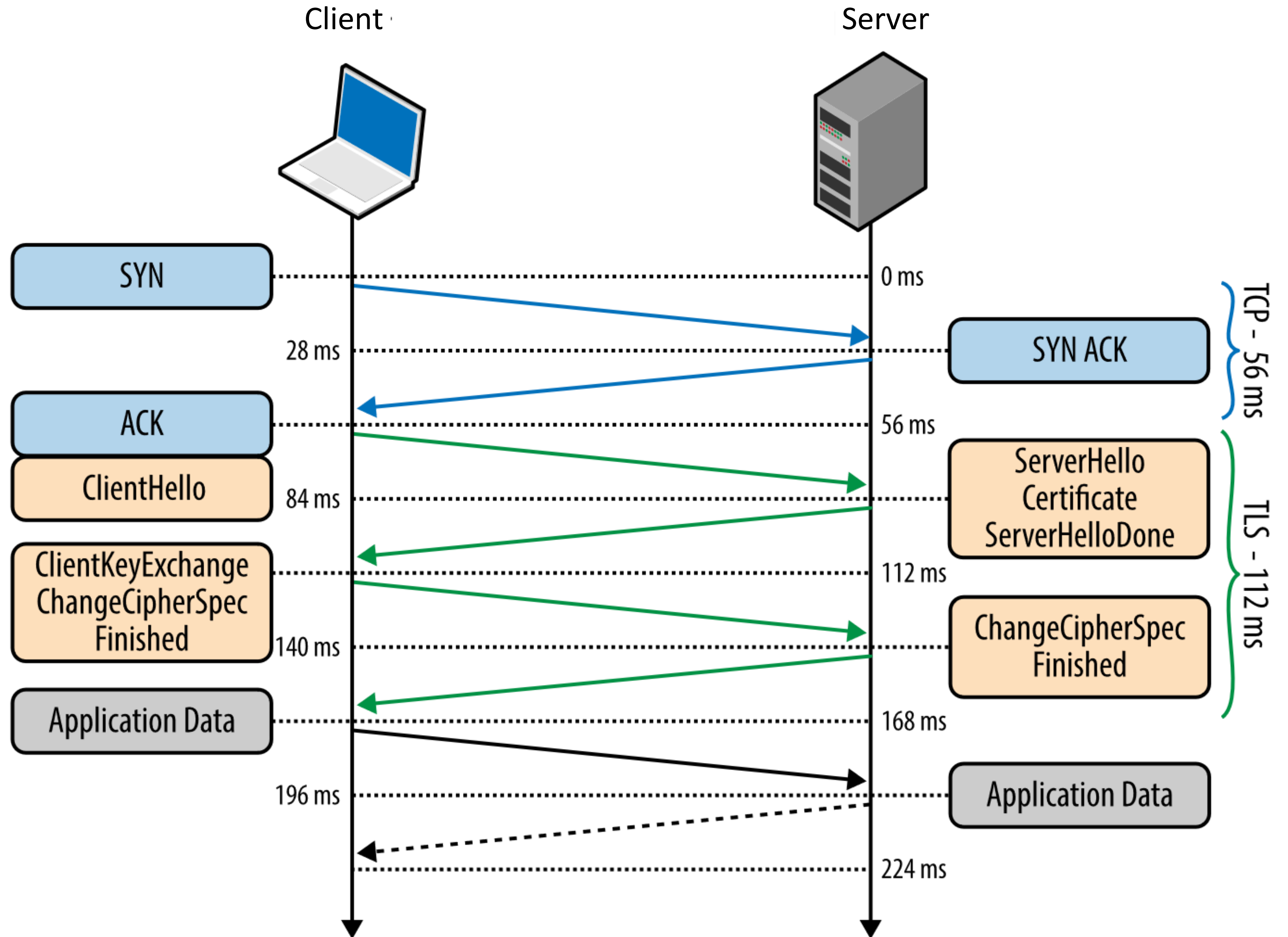
	Protocol	Published	Status
 NETSCAPE®	SSL 1.0	Unpublished	Unpublished
	SSL 2.0	1995	Deprecated in 2011
	SSL 3.0	1996	Deprecated in 2015
 I E T F®	TLS 1.0	1999	Deprecated in 2020
	TLS 1.1	2006	Deprecated in 2020
	TLS 1.2	2008	
	TLS 1.3	2018	

Transport layer security (TLS)

TLS consists of **two** protocols:

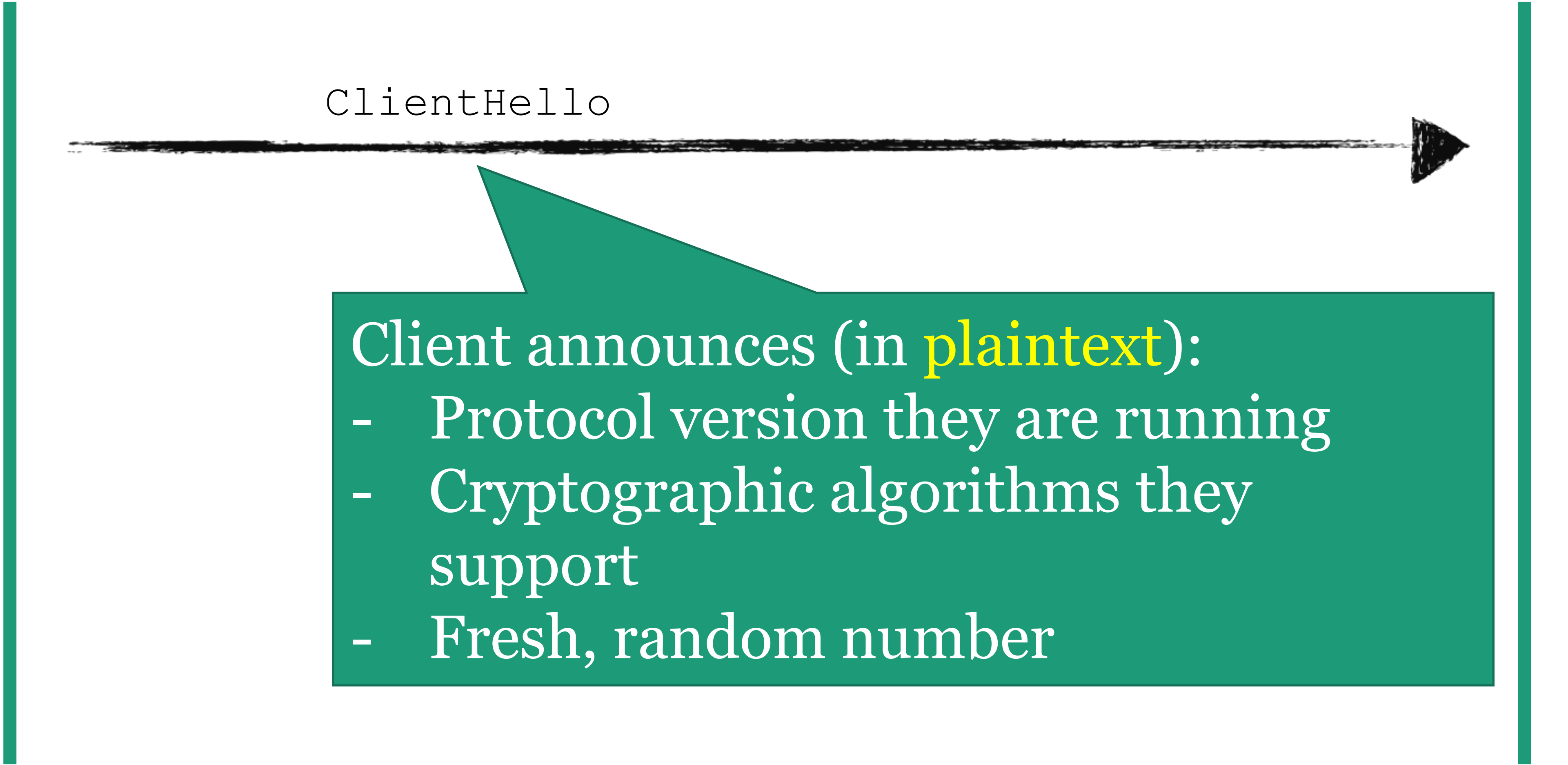
- Handshake protocol
 - Key agreement
 - Uses public-key cryptography to establish several shared secret keys between the client and the server
- Record layer protocol
 - How to encrypt
 - Uses the secret keys established in the handshake protocol to protect confidentiality, integrity, and authenticity of data exchange between the client and the server

TLS handshake



ClientHello

ClientHello

A diagram illustrating the ClientHello message transmission. A thick black arrow points from the Client side to the Server side. The arrow is labeled 'ClientHello' above it. A green callout box points to the arrow, containing details about the message content. The Client and Server sides are marked by vertical green lines at the bottom.

Client announces (in **plaintext**):

- Protocol version they are running
- Cryptographic algorithms they support
- Fresh, random number

Client

Server

Cipher Suites

- Set of algorithms supported by the client / server

- Example:

TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384

Protocol

Key Exchange
Algorithm

Authentication
Algorithm

Encryption
Algorithm

MAC

ciphersuite.info

337 Cipher Suites

- Ordering ▾
- Security ▾
- TLS Version ▾
- Library ▾
- Paginated
- Single Page

Secure	TLS_ECDHE_ECDSA_WITH_ARIA_128_CBC_SHA256
Insecure	TLS_NULL_WITH_NULL_NULL
Secure	TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA
Weak	TLS_ECDH_RSA_WITH_3DES_EDE_CBC_SHA
Insecure	TLS_DH_anon_WITH_ARIA_128_CBC_SHA256
Weak	TLS_ECDH_ECDSA_WITH_AES_128_GCM_SHA256
Secure	TLS_DHE_RSA_WITH_ARIA_128_CBC_SHA256
Secure	TLS_RSA_WITH_AES_128_CCM_8
Secure	TLS_RSA_WITH_AES_256_CCM_8
Weak	TLS_DH_RSA_WITH_AES_128_CBC_SHA
Secure	TLS_DHE_PSK_WITH_CAMELLIA_128_CBC_SHA256
Secure	TLS_PSK_DHE_WITH_AES_256_CCM_8
Insecure	TLS_DH_anon_WITH_ARIA_256_GCM_SHA384
Insecure	TLS_DHE_PSK_WITH_NULL_SHA256
Secure	TLS_ECDHE_ECDSA_WITH_CAMELLIA_128_CBC_SHA256
Insecure	TLS_ECDHE_PSK_WITH_RC4_128_SHA
Insecure	TLS_PSK_WITH_RC4_128_SHA
Weak	TLS_DH_RSA_WITH_CAMELLIA_256_GCM_SHA384
Secure	TLS_PSK_WITH_AES_256_CCM
Recommended	TLS_DHE_RSA_WITH_CHACHA20_POLY1305_SHA256

Secure Cipher Suite

IANA name:

TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384

OpenSSL name:

ECDHE-ECDSA-AES256-SHA384

GnuTLS name:

TLS_ECDHE_ECDSA_AES_256_CBC_SHA384

Hex code:

0xC0, 0x24

TLS Version(s):

TLS1.2

Protocol:

Transport Layer Security (TLS)

Key Exchange:

Elliptic Curve Diffie-Hellman Ephemeral (ECDHE)

Authentication:

Elliptic Curve Digital Signature Algorithm (ECDSA)

Encryption:

Advanced Encryption Standard with 256bit key in Cipher Block Chaining mode (AES 256 CBC)



Cipher Block Chaining:

The CBC mode is vulnerable to plain-text attacks with TLS 1.0, SSL 3.0 and lower. However a real fix is implemented with TLS 1.2 in which the GCM mode was introduced and which is not vulnerable to the BEAST attack. GCM should be preferred over CBC (cf. BEAST).

Hash:

Secure Hash Algorithm 384 (SHA384)

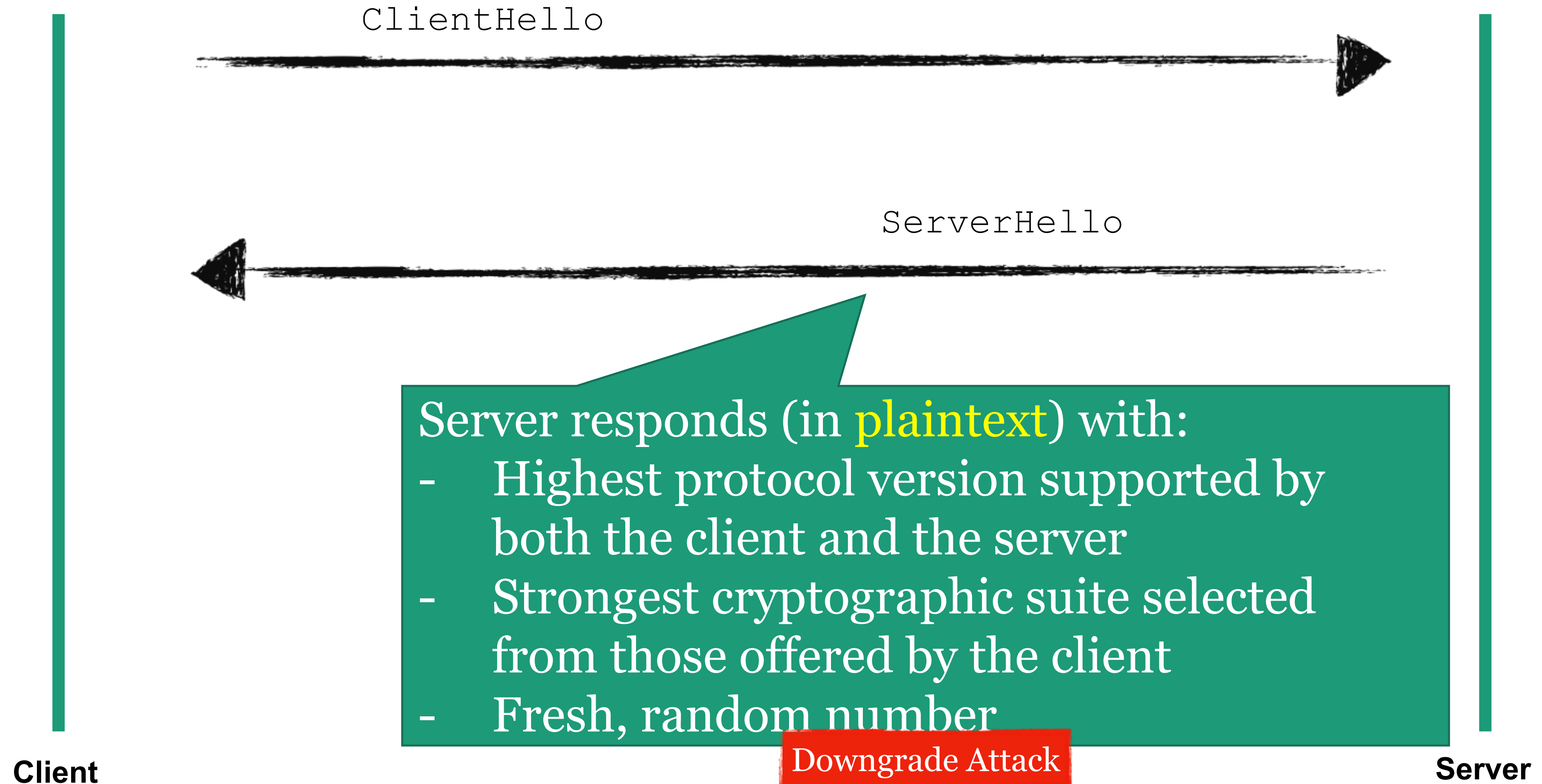
Included in RFC:

RFC 5289

Machine-readable:

application/json

ServerHello

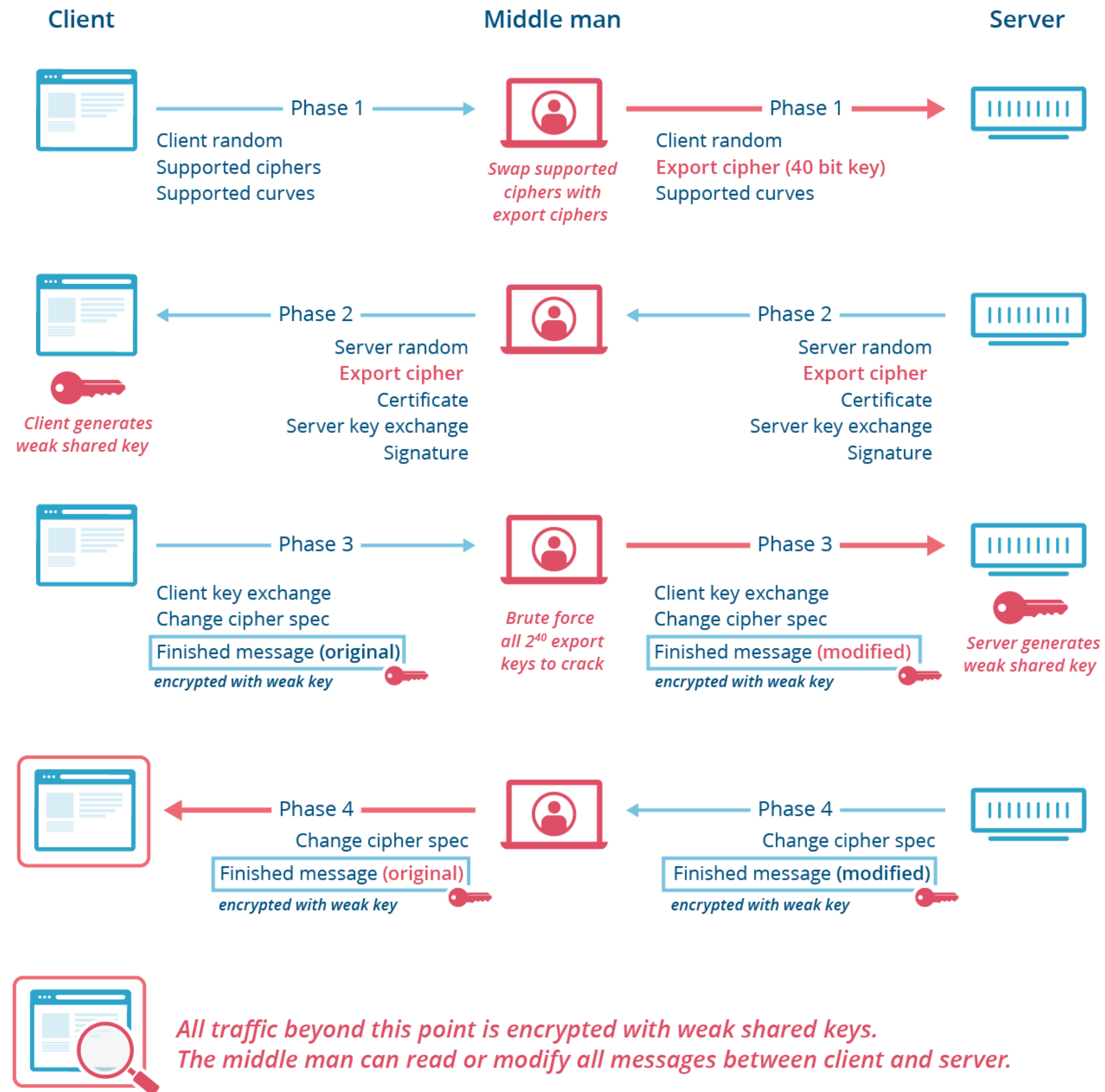


Downgrade Attacks (FREAK)

Export-Grade Cipher

512 bit of RSA key

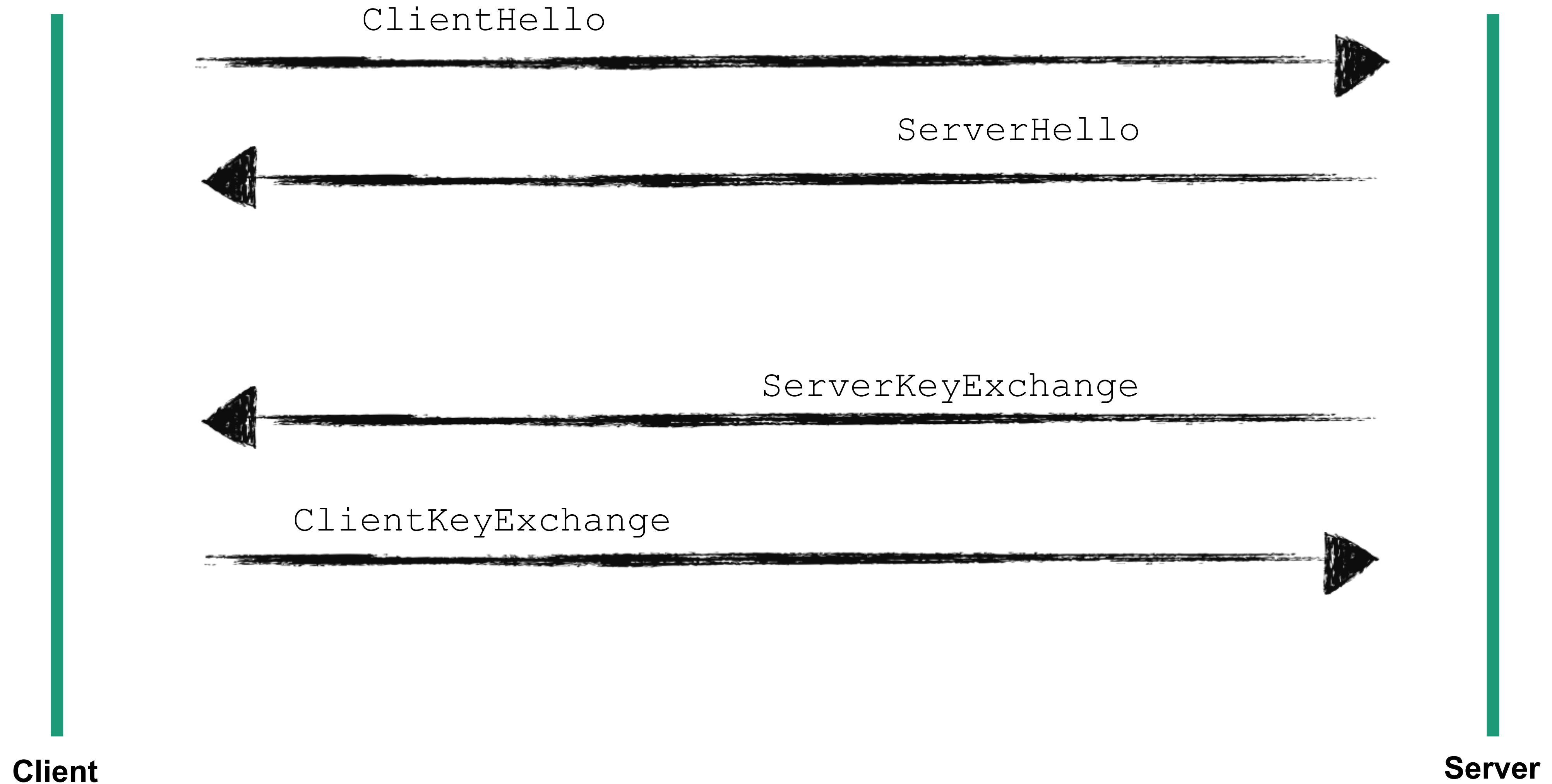
40 bit of symmetric ciphers



ServerKeyExchange

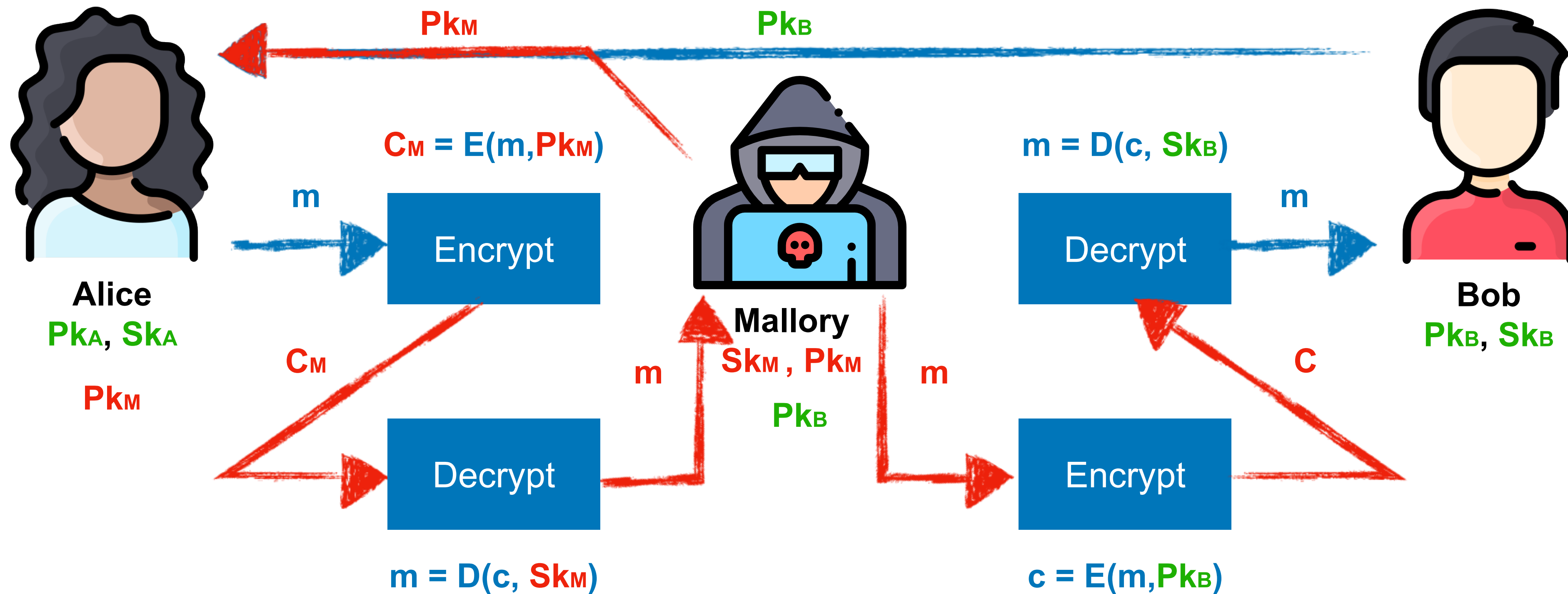


ClientKeyExchange



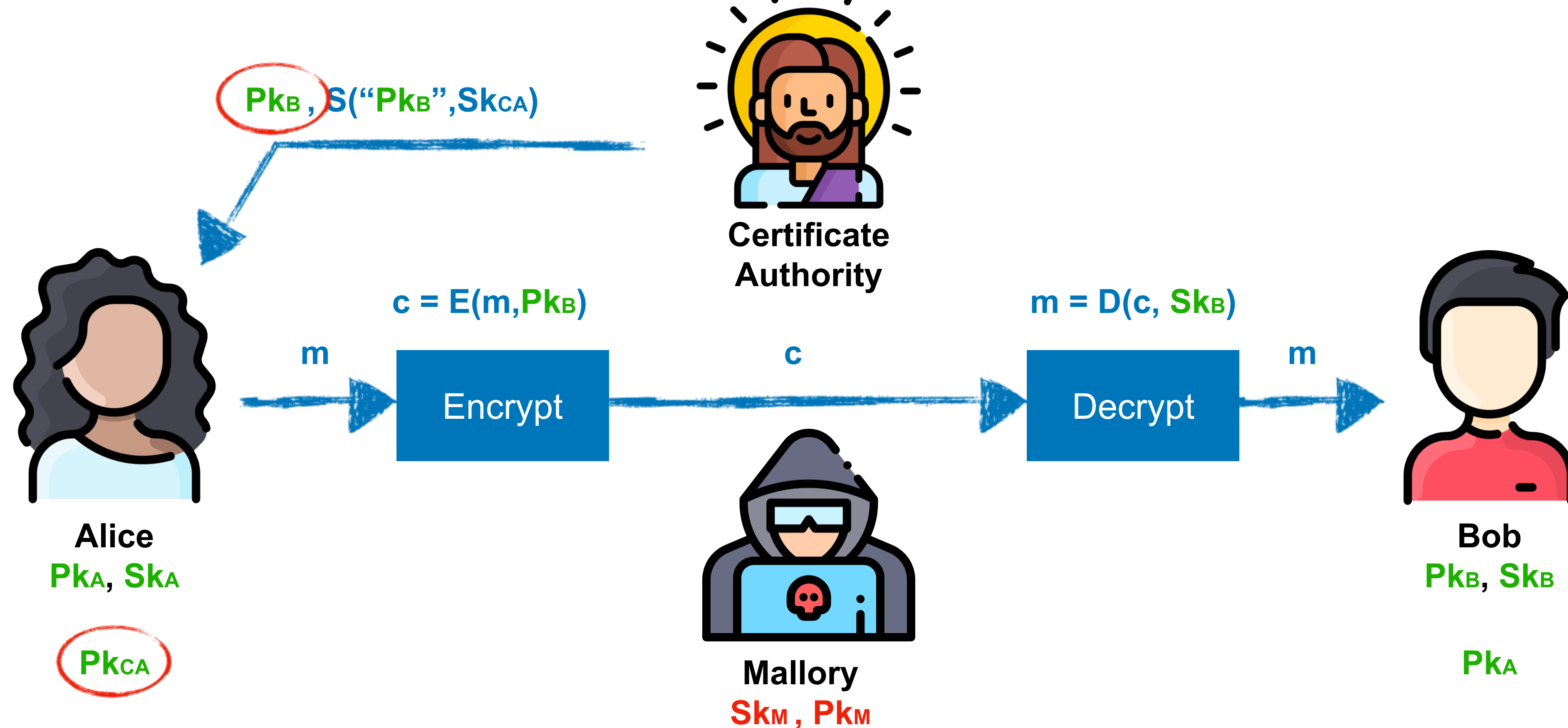
Recap

Man-in-the-Middle (MITM)



Recap

Distribution of Public Keys

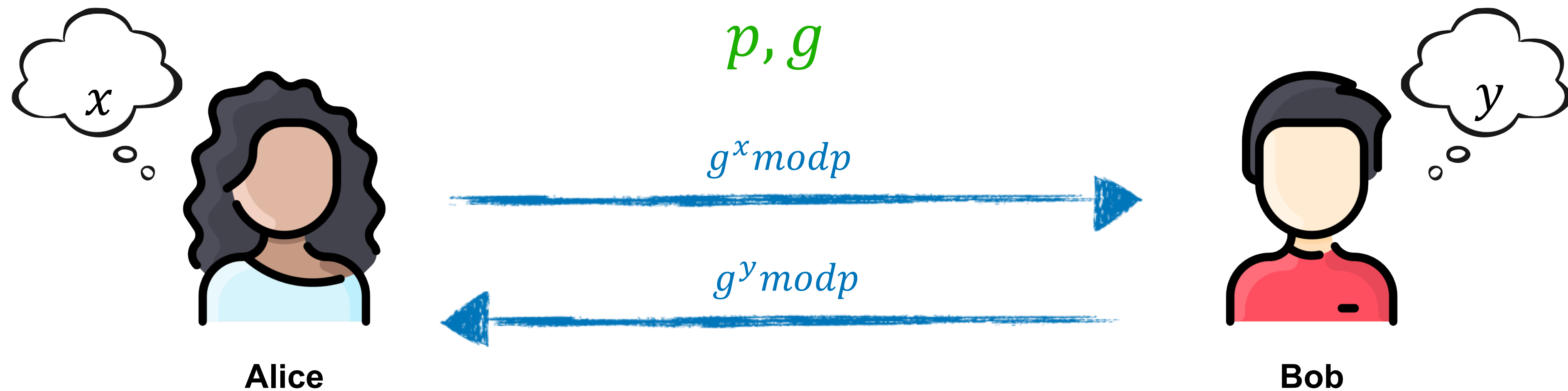


- After generating a private/public key pair, user **proves their identity** and **knowledge of the private key** to obtain CA's certificate for the public key
- Every computer is **pre-configured with CA's public key**

Recap

Key Agreement: Diffie-Hellman Protocol

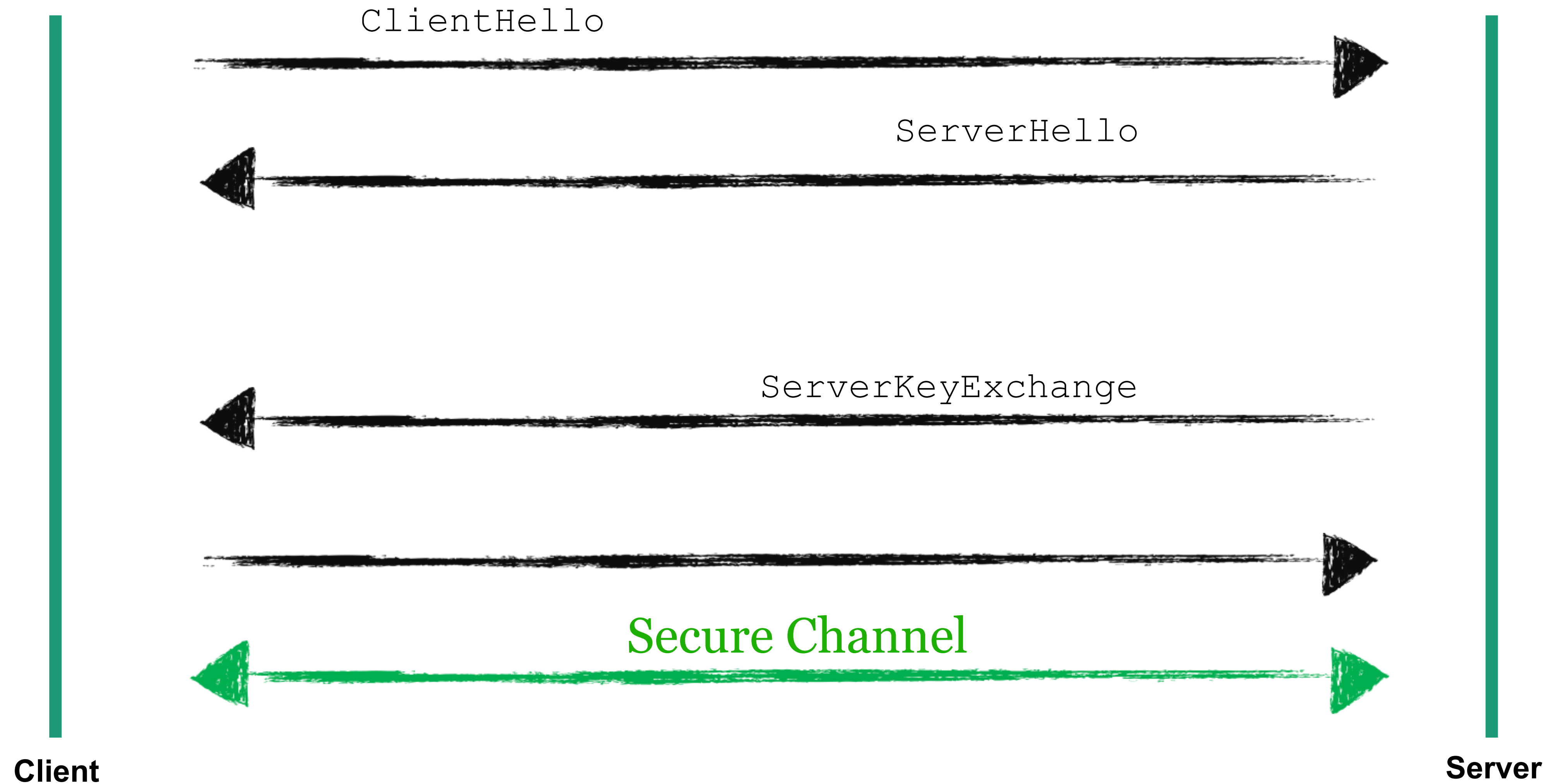
- Alice and Bob never met and share no secrets
- Alice and Bob publicly agree on **p** and **g**



Compute $k = (g^y)^x \bmod p = g^{xy} \bmod p$

Compute $k = (g^x)^y \bmod p = g^{xy} \bmod p$

Handshake Finished, secure channel established, or handshake aborted



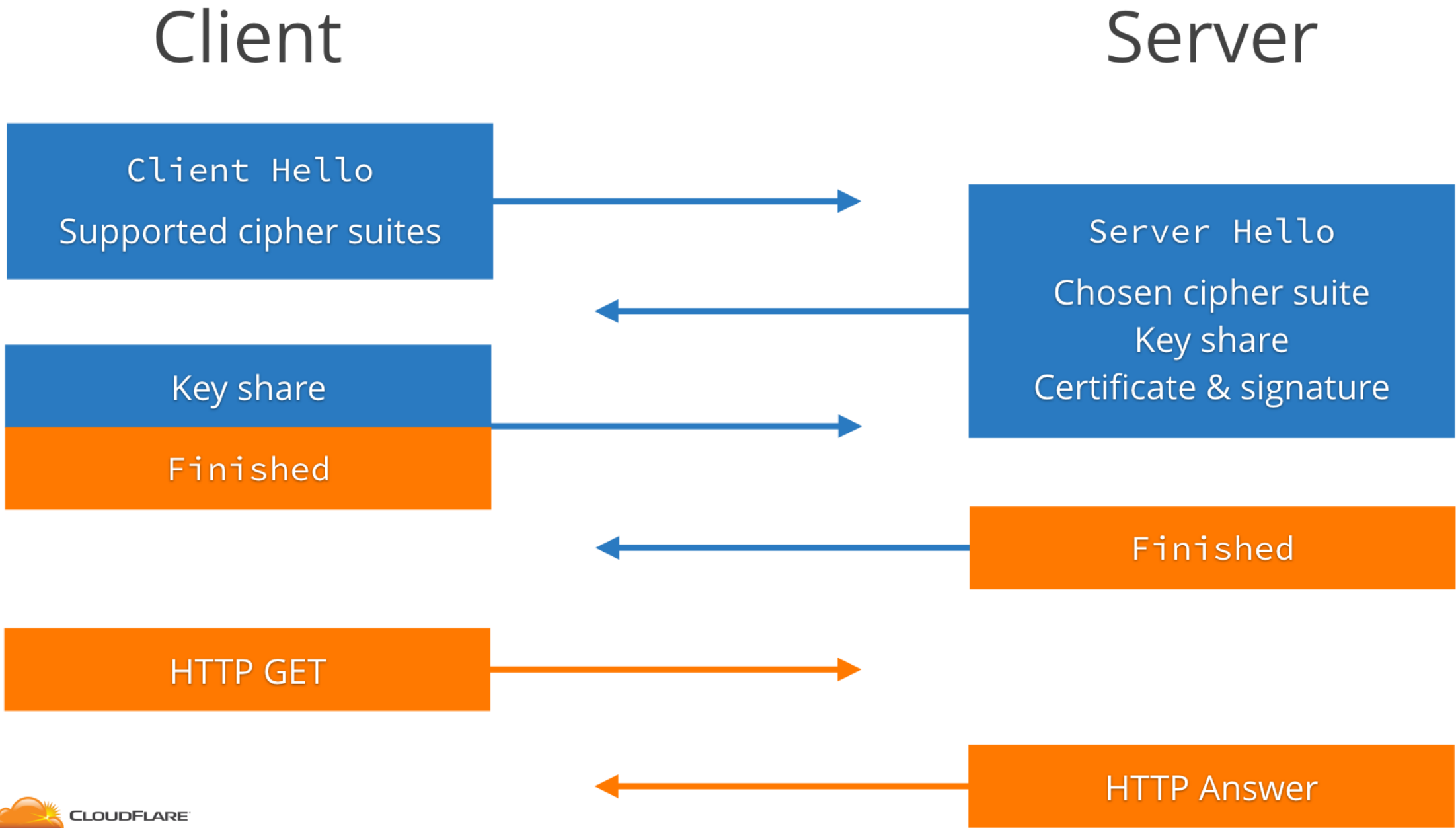
TLS

- Provides **confidentiality** and **integrity** above the transport layer
- Achieves **authenticity** through certificates.

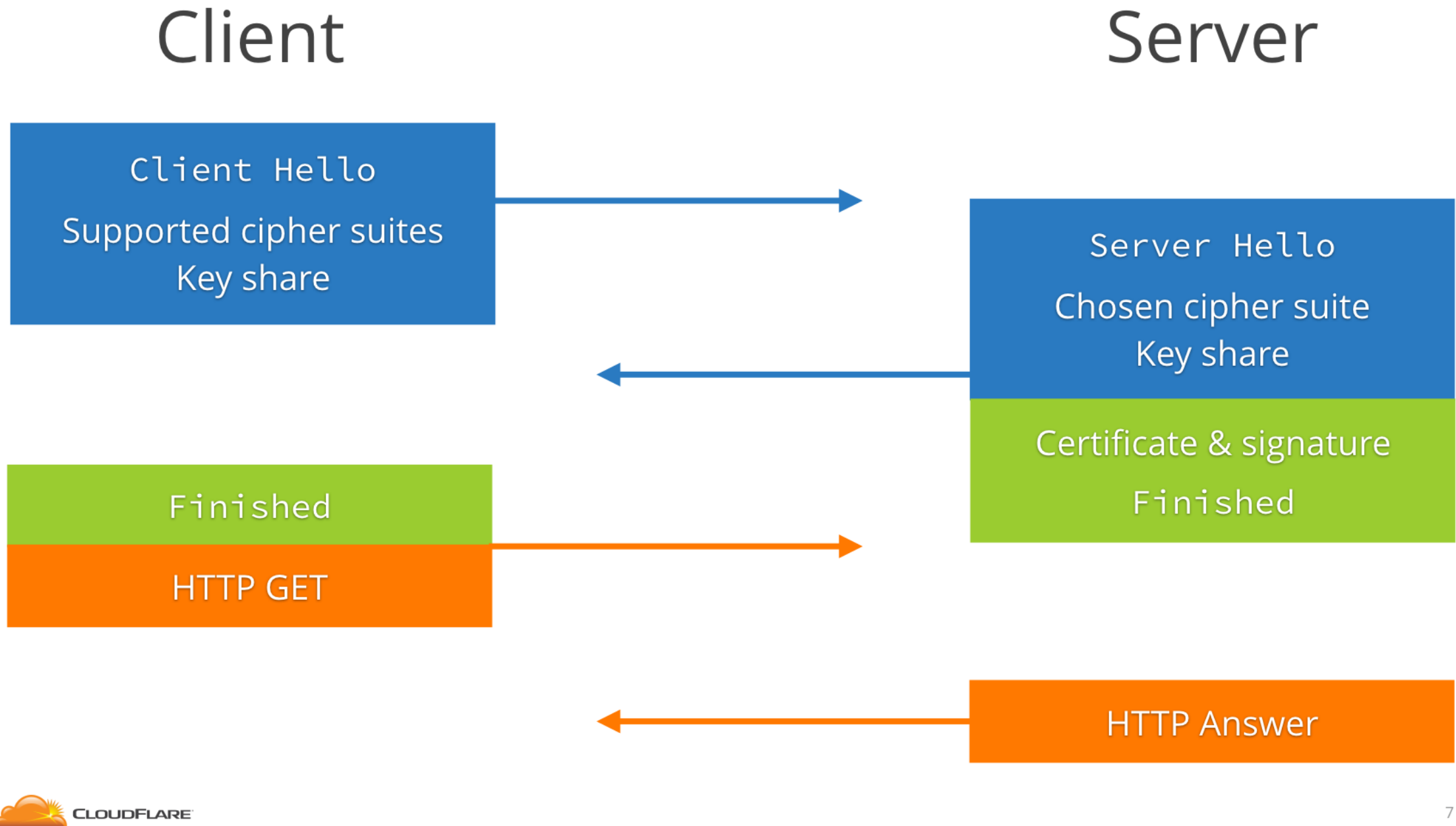
TLS 1.3

One less round-trip during handshake!

TLS 1.2



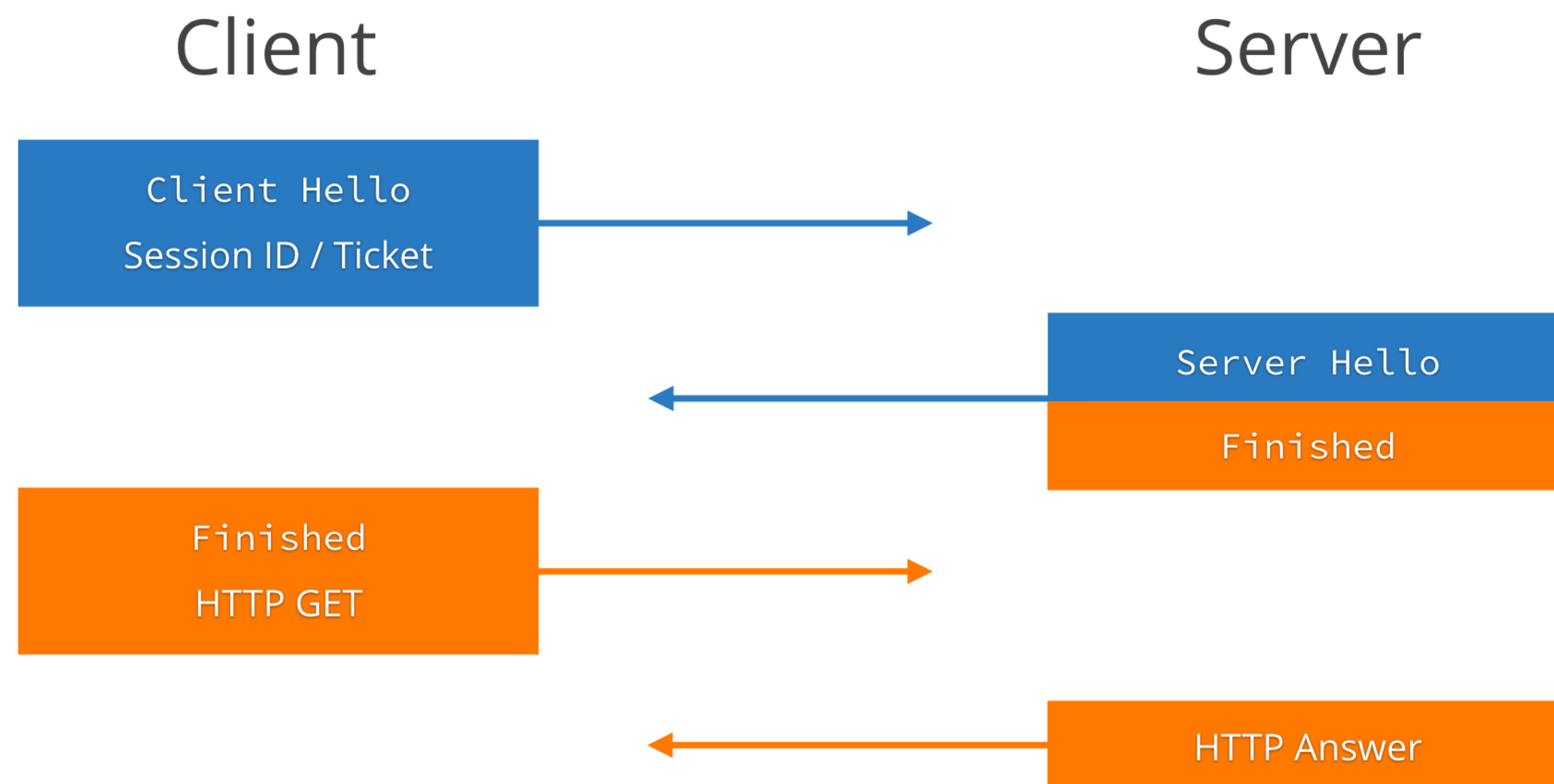
TLS 1.3



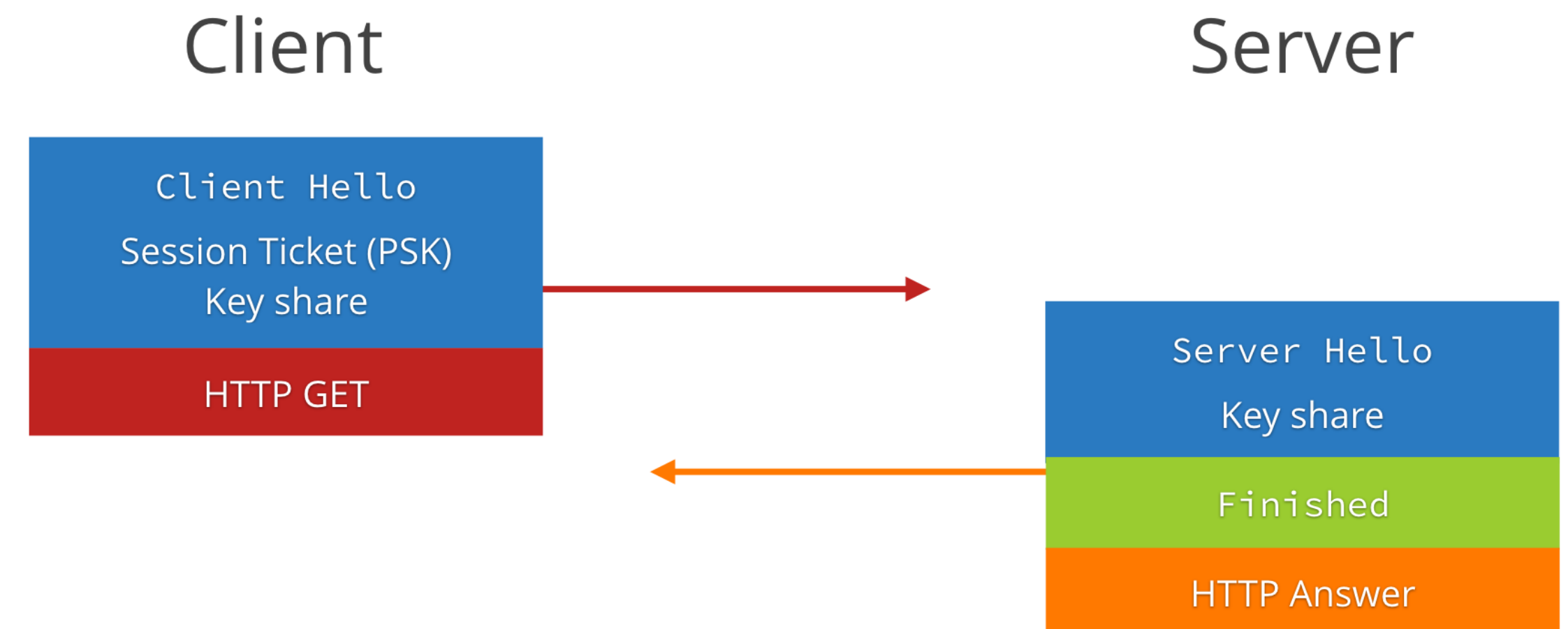
TLS 1.3

0-RTT Resumption

TLS 1.2



TLS 1.3



Two risks:

- Replayability
- No Forward Secrecy

TLS 1.3

Cipher suites

TLS 1.2

293 Cipher Suites

- Ordering
- Security
- TLS Version
- Library
- Paginated
- Single Page

Secure	TLS_ECDHE_ECDSA_WITH_ARIA_128_CBC_SHA256
Insecure	TLS_NULL_WITH_NULL_NULL
Secure	TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA
Weak	TLS_ECDH_ECDSA_WITH_AES_128_GCM_SHA256
Insecure	TLS_DH_anon_WITH_ARIA_128_CBC_SHA256
Secure	TLS_DHE_RSA_WITH_ARIA_128_CBC_SHA256
Secure	TLS_RSA_WITH_AES_128_CCM_8
Secure	TLS_RSA_WITH_AES_256_CCM_8
Weak	TLS_DH_RSA_WITH_AES_128_CBC_SHA
Secure	TLS_PSK_DHE_WITH_AES_256_CCM_8
Secure	TLS_DHE_PSK_WITH_CAMELLIA_128_CBC_SHA256
Insecure	TLS_DH_anon_WITH_ARIA_256_GCM_SHA384
Insecure	TLS_DHE_PSK_WITH_NULL_SHA256
Insecure	TLS_PSK_WITH_RC4_128_SHA
Insecure	TLS_ECDHE_PSK_WITH_RC4_128_SHA

TLS 1.3

5 Cipher Suites

- Ordering
- Security
- TLS Version
- Library
- Paginated
- Single Page

Recommended	TLS_CHACHA20_POLY1305_SHA256
Recommended	TLS_AES_128_GCM_SHA256
Recommended	TLS_AES_256_GCM_SHA384
Recommended	TLS_AES_128_CCM_SHA256
Recommended	TLS_AES_128_CCM_8_SHA256

Cipher Suites

TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384

Protocol

Key Exchange
Algorithm

Authentication
Algorithm

Encryption
Algorithm

MAC

TLS_AES_128_GCM_SHA256

Protocol

Encryption
Algorithm

MAC

ciphersuite.info

Secure Cipher Suite

IANA name:
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384

OpenSSL name:
ECDHE-ECDSA-AES256-SHA384

GnuTLS name:
TLS_ECDHE_ECDSA_AES_256_CBC_SHA384

Hex code:
0xC0, 0x24

TLS Version(s):
TLS1.2

Protocol:
Transport Layer Security (TLS)

Key Exchange:
Elliptic Curve Diffie-Hellman Ephemeral (ECDHE)

Authentication:
Elliptic Curve Digital Signature Algorithm (ECDSA)

Encryption:
Advanced Encryption Standard with 256bit key in Cipher Block Chaining mode (AES 256 CBC)

 **Cipher Block Chaining:**
The CBC mode is vulnerable to plain-text attacks with TLS 1.0, SSL 3.0 and lower. However a real fix is implemented with TLS 1.2 in which the GCM mode was introduced and which is not vulnerable to the BEAST attack. GCM should be preferred over CBC (cf. BEAST).

Hash:
Secure Hash Algorithm 384 (SHA384)

Included in RFC:
RFC 5289

Machine-readable:
application/json

Recommended Cipher Suite

IANA name:
TLS_AES_256_GCM_SHA384

OpenSSL name:
TLS_AES_256_GCM_SHA384

Hex code:
0x13, 0x02

TLS Version(s):
TLS1.3

Protocol:
Transport Layer Security (TLS)

Key Exchange:
-

Authentication:
-

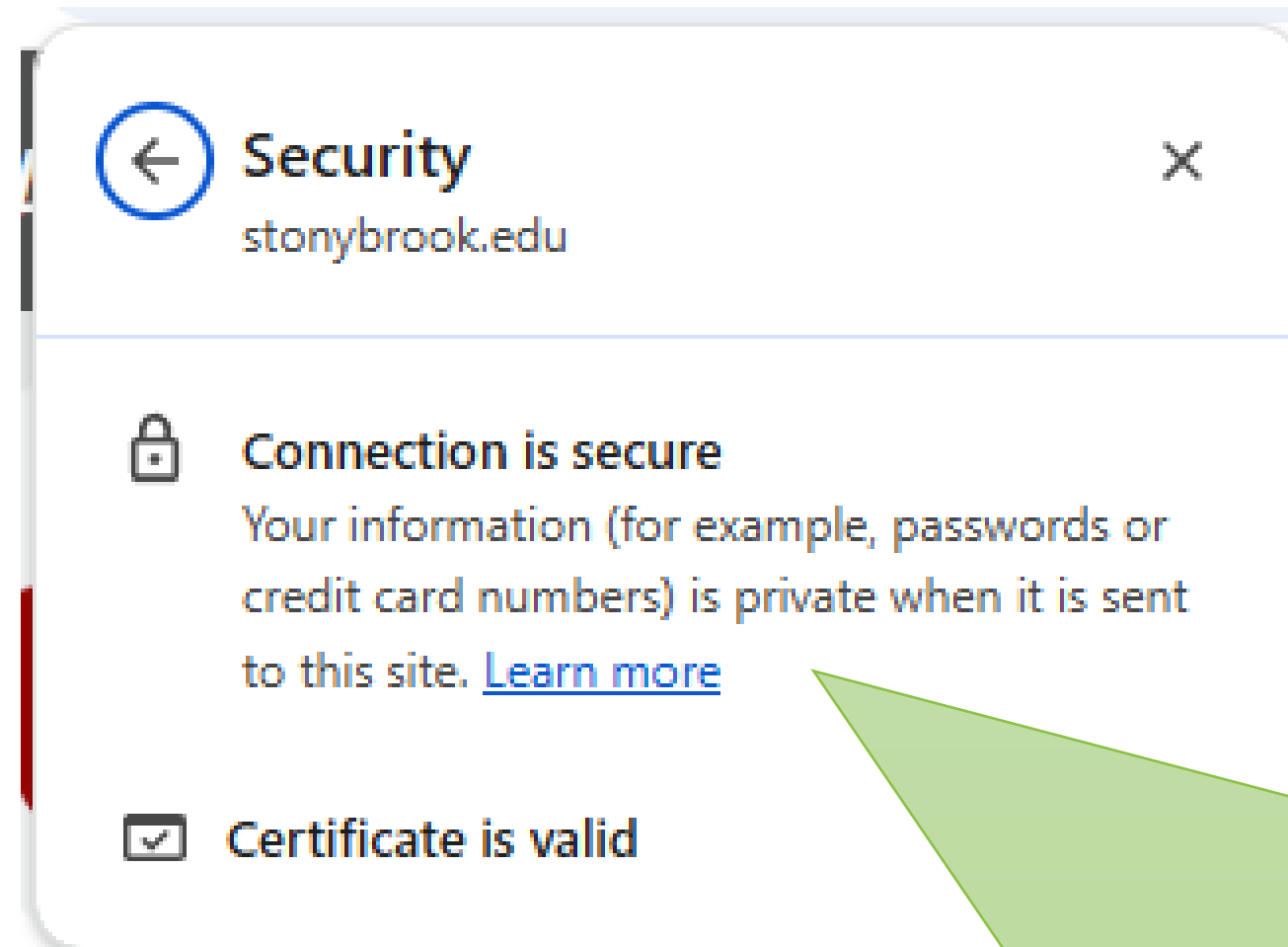
Encryption:
Advanced Encryption Standard with 256bit key in Galois/Counter mode (AES 256 GCM)

Hash:
Secure Hash Algorithm 384 (SHA384)

Included in RFC:
RFC 8446

Machine-readable:
application/json

TLS + HTTP => HTTPS



HTTPS Lock: What does it guarantee?

1. **Source authentication**: The source of the rendered content of the website is indeed from “stonybrook.edu”
2. **Content integrity**: The content of the website is not tampered in transit.